THOMSON
COURSE TECHNOLOGY

# Guide to Network Defense and Countermeasures
# Third Edition

*Chapter 1*

*Network Defense Fundamentals*

# Objectives

- Describe the threats to network security
- Explain the goals of network security
- Describe a layered approach to network defense
- Explain how network security defenses affect your organization


© Cengage Learning 2014

# Overview of Threats to Network Security

- Network intrusions cause:
  - Loss of data
  - Loss of privacy
  - Other problems
- Businesses must actively address information security


© Cengage Learning 2014

# Threats to Network Security, Part 1

- Knowing the types of attackers helps you anticipate
- Motivation to break into systems
  - Status
  - Revenge
  - Financial gain
  - Industrial espionage


© Cengage Learning 2014

# Threats to Network Security, Part 2

- Hackers
  - Attempt to gain access to unauthorized resources
    - Circumventing passwords, firewalls, or other protective measures
- Disgruntled employees
  - Usually unhappy over perceived injustices
  - Steal information to give confidential information to new employers
  - When an employee is terminated, security measures should be taken immediately


© Cengage Learning 2014

# Threats to Network Security, Part 3

- Terrorists
  - Attack computer systems for several reasons
    - Making a political statement
    - Achieving a political goal
      - Example: release of a jailed comrade
    - Causing damage to critical systems
    - Disrupting a target's financial stability
- Government Operations
  - A number of countries see computer operations as a spying technique


© Cengage Learning 2014

# Threats to Network Security, Part 4

- Malicious Code
  - Malware
  - Use system's well known vulnerabilities to spread
- Viruses
  - Executable code that copies itself from one place to another
  - Can be benign or harmful
  - Spread methods
    - Running executable code
    - Sharing disks or memory sticks
    - Opening e-mail attachments
    - Viewing infected Web pages


© Cengage Learning 2014

# Threats to Network Security, Part 5

- Worm
  - Creates files that copy themselves and consume disk space
  - Does not require user intervention to be launched
  - Some worms install **back doors**
    - A way of gaining unauthorized access to computer or other resources
  - Others can destroy data on hard disks
- Trojan program
  - Harmful computer program that appears to be something useful
  - Can create a back door to open system to additional attacks


© Cengage Learning 2014

# Threats to Network Security, Part 6

- Macro viruses
  - Macro is a type of script that automates repetitive tasks in Microsoft Word or similar applications
  - Macros run a series of actions automatically
  - Macro viruses run actions that tend to be harmful
- Other Threats to Network Security
  - It is not possible to prepare for every possible risk to your systems
  - Try to protect your environment for today's threat
  - Be prepared for tomorrow's threats


© Cengage Learning 2014

# Threats to Network Security, Part 7

- Social Engineering: The People Factor
  - Attackers try to gain access to resources through people
  - Employees are fooled by attackers into giving out passwords or other access codes
  - To protect against employees who do not always observe accepted security practices:
    - Organizations need a strong and consistently enforced security policy and rigorous training program


© Cengage Learning 2014

# Common Attacks and Defenses, Part 1

| Attack | Description | Defense |
|---|---|---|
| Denial of service (DoS) attack | The traffic into and out of a network is blocked when servers are flooded with malformed packets (bits of digital information) that contain false IP addresses, other harmful data, or other fake communications. | Keep your server OS up to date; log instances of frequent connection attempts against one service. |
| SYN flood | A network is overloaded with packets that have the SYN flag set. Servers are overloaded with requests for connections and are unable to respond to legitimate requests (a denial of service attack). | Keep your firewall and OS up to date so that these attacks are blocked by means of software patches and updates, and review your log files of access attempts to see whether intrusion attempts have been made. |
| Virus | Network computers are infected by viruses. | Install antivirus software and keep virus definitions up to date. Keep applications and operating systems patched. |
| Trojan program | A user installs a malicious Trojan program that can create a "back door" an attacker can exploit. | Install antivirus software and keep virus definitions up to date. Keep applications and operating systems patched. |
| Social engineering | An employee is misled into giving out passwords or other sensitive information. | Educate employees about your security policy, which is a set of goals and procedures for making an organization's network secure. |
| Malicious port scanning | An attacker looks for open ports to infiltrate a network. | Install and configure a firewall, which is hardware and/or software designed to filter out unwanted network traffic and protect authorized traffic. |
| Internet Control Message Protocol (ICMP) message abuse | A network is flooded with a stream of ICMP echo requests to a target computer. | Set up packet filtering. |
| Man-in-the-middle attack | An attacker operates between two computers in a network and impersonates one computer to intercept communications. | Use VPN encryption. |
| Finding vulnerable hosts on the internal network to attack | An attacker who gains access to one computer on a network can get IP addresses, host names, and passwords, which are then used to find other hosts to attack. | Use proxy servers. |
| New files being placed on the system | A virus or other program causes new files to proliferate on infected computers, using up system resources. | Install system-auditing software. |
| Remote Procedure Calls (RPC) attacks | The operating systems crash because they are unable to handle arbitrary data sent to an RPC port. | Set up an IDPS (intrusion detection and prevention system). |


© Cengage Learning 2014

# Common Attacks and Defenses, Part 2

| Attack | Description | Defense |
|---|---|---|
| Application vulnerability exploits | Unpatched or vulnerable client-side applications that can be invoked and then misused by browsers are targeted, often by trusted Web sites converted into malicious servers. | Keep applications patched. Maintain software inventories so vulnerable software is accounted for and defended. Ensure secure configurations of all software and use perimeter defenses to help identify and prevent attacks. |
| Web application attacks | Brute force password guessing is used to gain a valid username/password pair. Popular targets of this attack are Microsoft SQL, SSH servers, and FTP. Cross-site scripting, SQL injection, and PHP File Include attacks are the most popular methods for compromising Web sites. | Perimeter defenses should be used to ensure that layered defenses identify and prevent attacks aimed at Web servers. Log files can help determine if your Web server has been compromised. Ensure that all applications and operating systems are patched regularly. |

# Internet Security Concerns

- Socket
  - Port number combined with a computer's IP address constitutes a network connection
- Attacker software looks for open sockets
  - Open sockets are an invitation to be attacked
  - Sometimes sockets have exploitable vulnerabilities
  - Hypertext Transport Protocol (HTTP) uses port 80
    - HTTP is among most commonly exploited services


© Cengage Learning 2014

# E-mail and Communications

- Home users who regularly surf the Web, use e-mail and instant messaging programs
  - Personal firewalls keep viruses and Trojan programs from entering a system
  - Norton/McAfee are examples of personal firewall program


© Cengage Learning 2014

# Scripting

- A network intrusion that is increasing in frequency is the use of **scripts**
  - Executable code attached to e-mail messages or downloaded files that infiltrates a system
  - Difficult for firewalls and intrusion-detection and prevention systems (IDPSs) to block all scripts
  - Specialty firewalls and other programs should be integrated with existing security systems to keep scripts from infecting a network
    - A specialty email firewall can monitor ad control certain types of content that pass into and out of a network


© Cengage Learning 2014

# Always-On Connectivity

- Computers using always-on connections are easier to locate and attack
  - IP addresses remain the same as long as they are connected to the Internet
- Remote users pose security problems to network administrators
  - Network security policy should specify that remote users have their computers equipped with firewall and antivirus protection software
- Always-on connections effectively extend the boundaries of your corporate network


© Cengage Learning 2014

# Goals of Network Security

- Providing Secure Connectivity
- Secure Remote Access
- Ensuring Privacy
- Providing Nonrepudiation
- Confidentiality, Integrity, and Availability


© Cengage Learning 2014

# Providing Secure Connectivity

- In the past, network security emphasized blocking attackers from accessing the corporate network
  - Now secure connectivity with trusted users and networks is the priority
- Activities that require secure connectivity
  - Placing orders for merchandise online
  - Paying bills
  - Accessing account information
  - Looking up personnel records
  - Creating authentication information


© Cengage Learning 2014

# Secure Remote Access

- One of the biggest security challenges is to provide secure remote access for contractors and traveling employees
- VPN
  - Uses a combination of encryption and authentication mechanisms
  - Ideal and cost-effective solution
  - VPNs are explained in more detail in Chapter 11


© Cengage Learning 2014

# Secure Remote Access Using VPNs

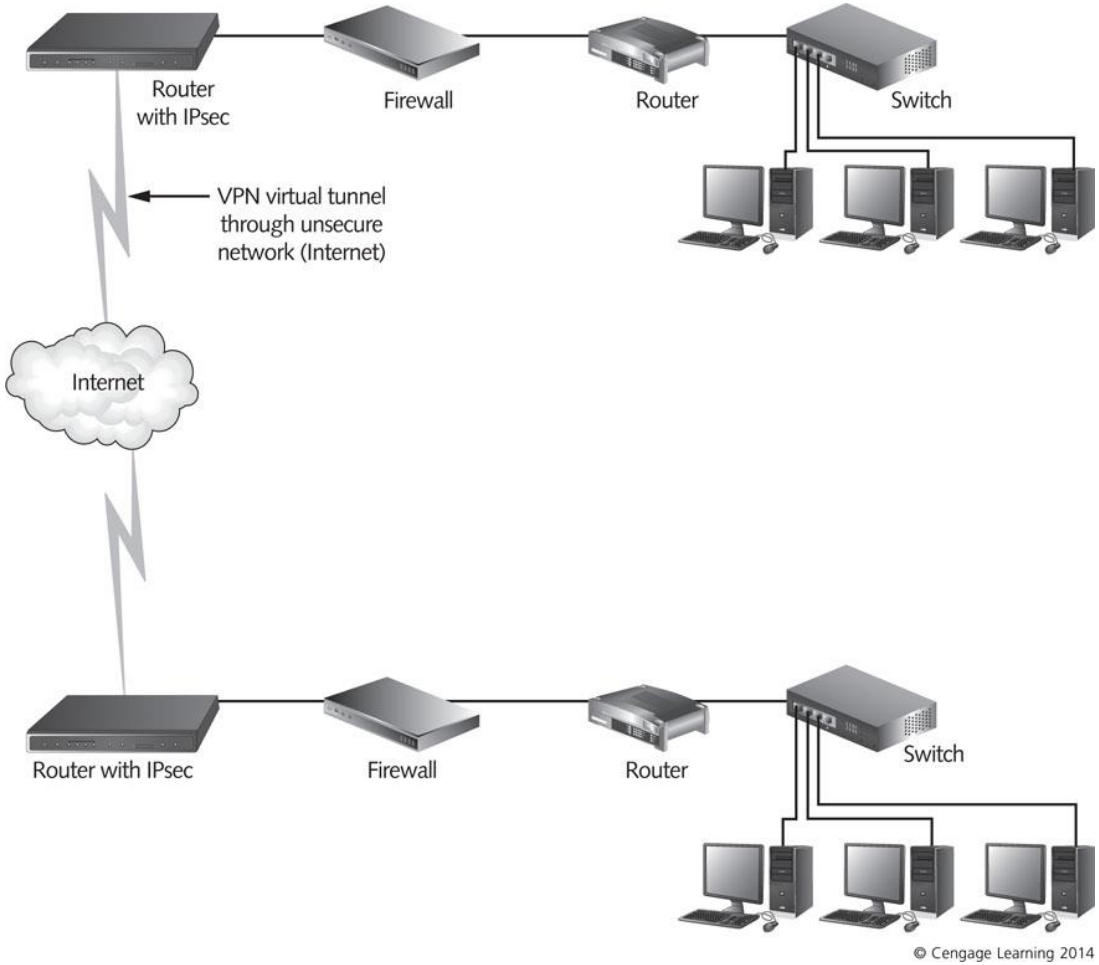



**Figure 1-1** Many businesses provide secure remote access using VPNs


© Cengage Learning 2014

# Ensuring Privacy

- Databases with personal or financial information need to be protected
  - US laws exist that protect private information
    - Mandates severe penalties for failure to protect it
- Education is an effective way to maintain the privacy of information
  - All employees must be educated about security dangers and security policies
  - Employees are most likely to detect security breaches
    - And to cause one accidentally
  - Employees can monitor activities of their co-workers


© Cengage Learning 2014

# Providing Nonrepudiation

- Nonrepudiation: capability to prevent a participant in an electronic transaction from denying that it performed an action
  - Ensuring that the sender cannot deny sending a message and the recipient cannot deny receiving it
- Encryption provides integrity, confidentiality, and authenticity of digital information
  - Encryption can also provide nonrepudiation
- Nonrepudiation is an important aspect of establishing trusted communication between organizations


© Cengage Learning 2014

# Confidentiality, Integrity, and Availability

- Confidentiality
  - Prevents intentional or unintentional disclosure of communications between sender and recipient
- Integrity
  - Ensures the accuracy and consistency of information during all processing
    - Creation, storage, and transmission
- Availability
  - Assurance that authorized users can access resources in a reliable and timely manner


© Cengage Learning 2014

# Using a Layered Defense Strategy: Defense in Depth, Part 1

- No single security measure can ensure complete network protection
- Instead, assemble a group of methods
  - That work in a coordinated fashion
- Defense in depth (DiD)
  - Layering approach to network security
  - Designed by the National Security Agency (NSA) as a best practices strategy for achieving information assurance


© Cengage Learning 2014

# Using a Layered Defense Strategy: Defense in Depth, Part 2

- In general, the layers are:
  - Physical security
  - Authentication and password security
  - Operating system security
  - Antivirus protection
  - Packet filtering
  - Firewalls
  - Demilitarized zone (DMZ)
  - Intrusion detection and prevention system (IDPS)
  - Virtual private networks (VPNs)
  - Network auditing and log files
  - Routing and access control methods


© Cengage Learning 2014

# Physical Security

- Refers to measures taken to physically protect a computer or other network device
- Physical security measures
  - Computer locks
  - Lock protected rooms for critical servers
  - Burglar alarms
- A computer can easily be compromised if a malicious intruder has physical access to it


© Cengage Learning 2014

# Authentication and Password Security

- Password security
  - Simple strategy
  - Select good passwords, keep them secure, and change them as needed
  - Use different passwords for different applications
- Authentication – verifying the identity of a user, service, or computer
  - Uses three methods
    - Verifying something a user knows (basic authentication)
    - Verifying something a user has
    - Verifying something a user is
- In large organizations, authentication is handled by centralized servers


© Cengage Learning 2014

# Operating System Security

- OSs must be timely updated to protect from security flaws
- Protect operating systems by installing
  - Patches
  - Hot fixes
  - Service packs
- Stop any unneeded services
- Disable Guest accounts


© Cengage Learning 2014

# Antivirus Protection

- Virus scanning
  - Examines files or e-mail messages for indications that viruses are present
- Viruses have suspicious file extensions
- Antivirus software uses virus signatures to detect viruses in your systems
  - You should constantly update virus signatures
- Firewalls and IDPSs are not enough
- You should install antivirus software in hosts and all network computers


© Cengage Learning 2014

# Packet Filtering

- Block or allow transmission of packets based on
  - Port number
  - IP addresses
  - Protocol information
- Some types of packet filters
  - Routers
    - Most common packet filters
  - Operating systems
    - Built-in packet filtering utilities that come with some OSs
  - Software firewalls
    - Enterprise-level programs


© Cengage Learning 2014

# Firewalls

- Installing and configuring a firewalls is the foundation of organization's overall security policy
- Permissive versus restrictive policies
  - Permissive
    - Allows all traffic through the gateway and then blocks services on case-by-case basis
  - Restrictive
    - Denies all traffic by default and then allows services on case-by-case basis
- Enforcement is handled primarily through setting up packet-filtering rules


© Cengage Learning 2014

# Permissive versus Restrictive Firewall Policies

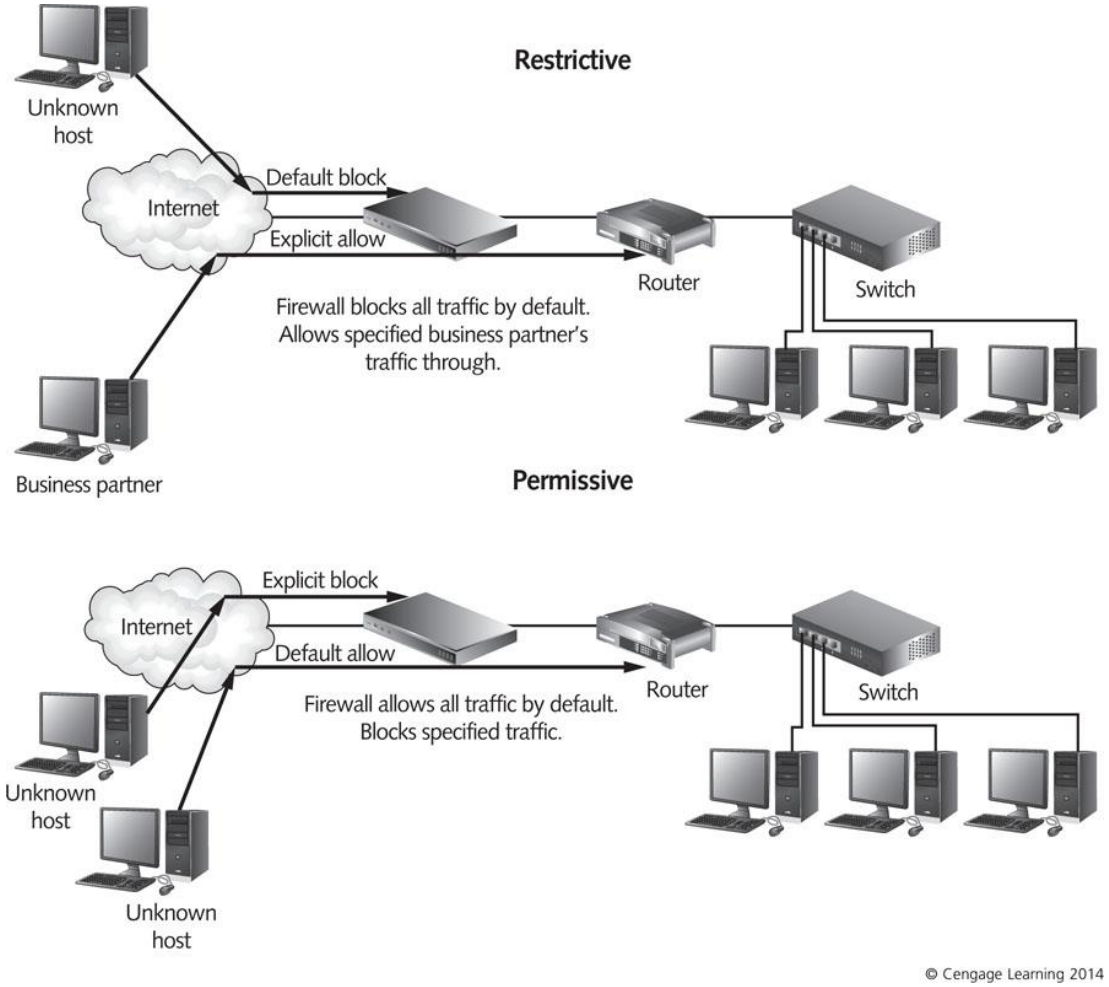



**Figure 1-2** Permissive vs. restrictive firewall policies


© Cengage Learning 2014

# Demilitarized Zone (DMZ)

- Network that sits outside the internal network
  - DMZ is connected to the firewall
- Makes services like HTTP and FTP publicly available
  - While protecting the internal LAN
- It might also contain a DNS server
  - DNS server resolves domain names to IP addresses
- DMZ is sometimes called a “service network” or “perimeter network”


© Cengage Learning 2014

# Firewall Used to Create a DMZ and Protect the Internal Network

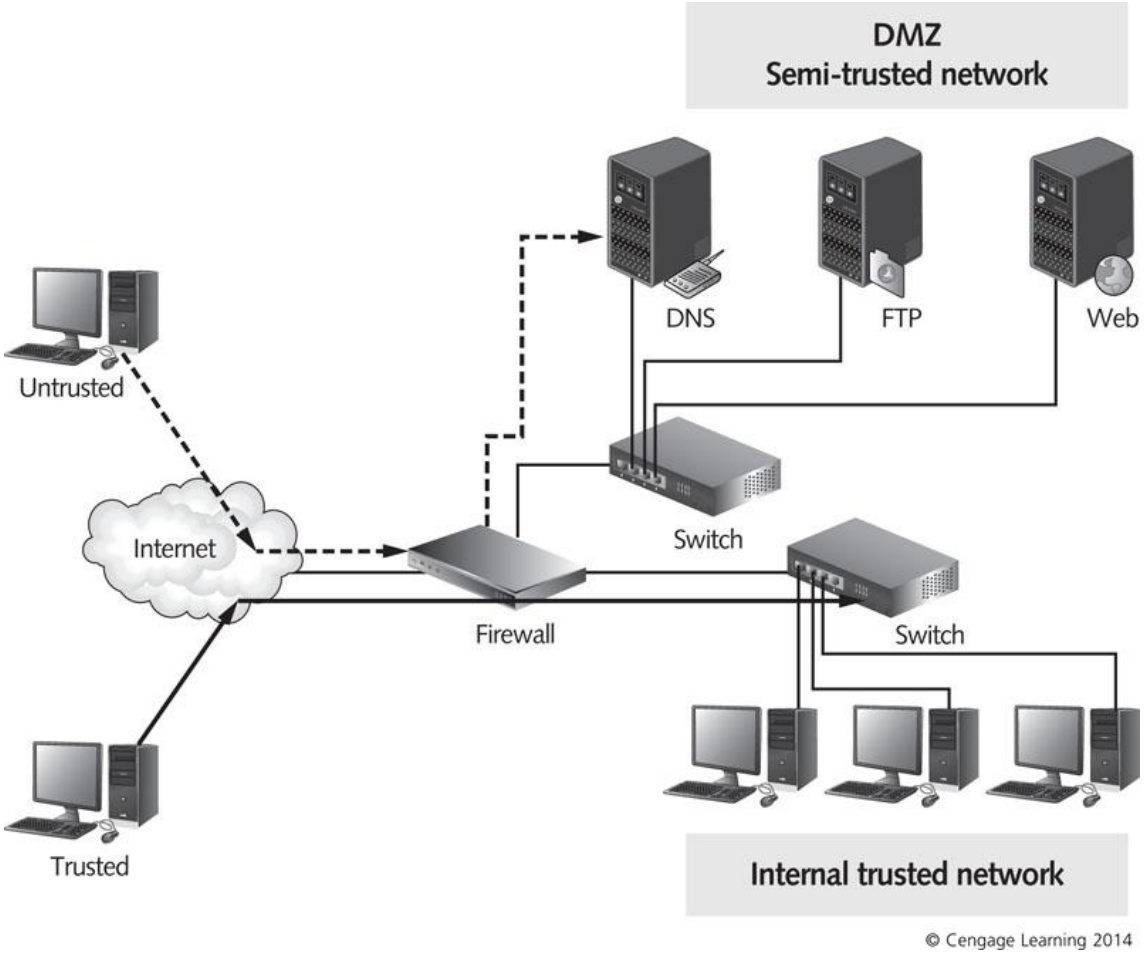



**Figure 1-3** Firewall used to create a DMZ and protect the internal network

# Intrusion Detection and Prevention System (IDPS)

- Use of an IDPS offers an additional layer of protection
- Works by recognizing the signs of a possible attack
  - Notifies the administrator
- Some traffic can trigger a response that attempts to actively combat the threat (intrusion prevention)
- Signs of possible attacks are called signatures
  - Combinations of IP address, port number, and frequency of access attempts


© Cengage Learning 2014

# Virtual Private Networks (VPNs)

- A VPN is a network that uses public telecommunications infrastructure to provide secure access to corporate assets for remote users
  - Provide a low-cost and secure connection that uses the public Internet
- Alternative to expensive leased lines
  - Provides point-to-point communication
- Use authentication to verify users' identities and encrypt and encapsulate traffic


© Cengage Learning 2014

# Network Auditing and Log Files, Part 1

- Auditing
  - Recording which computers are accessing a network and what resources are being accessed
  - Information is recorded in a log file
- Reviewing and maintaining log files helps you detect suspicious patterns of activity
  - Example: regular and unsuccessful connection attempts that occur at the same time each day
- You can set up rules to block attacks based on logged information from previous attack attempts


© Cengage Learning 2014

# Network Auditing and Log Files, Part 2

- Log file analysis
  - Tedious and time consuming task
  - Record and analyze rejected connection requests
  - Sort logs by time of day and per hour
  - Check logs during peak traffic time and use to identify services that consume bandwidth
- Configuring log files to record
  - System events
  - Security events
  - Traffic
  - Packets


© Cengage Learning 2014

# Graphic Display of Log File Entries

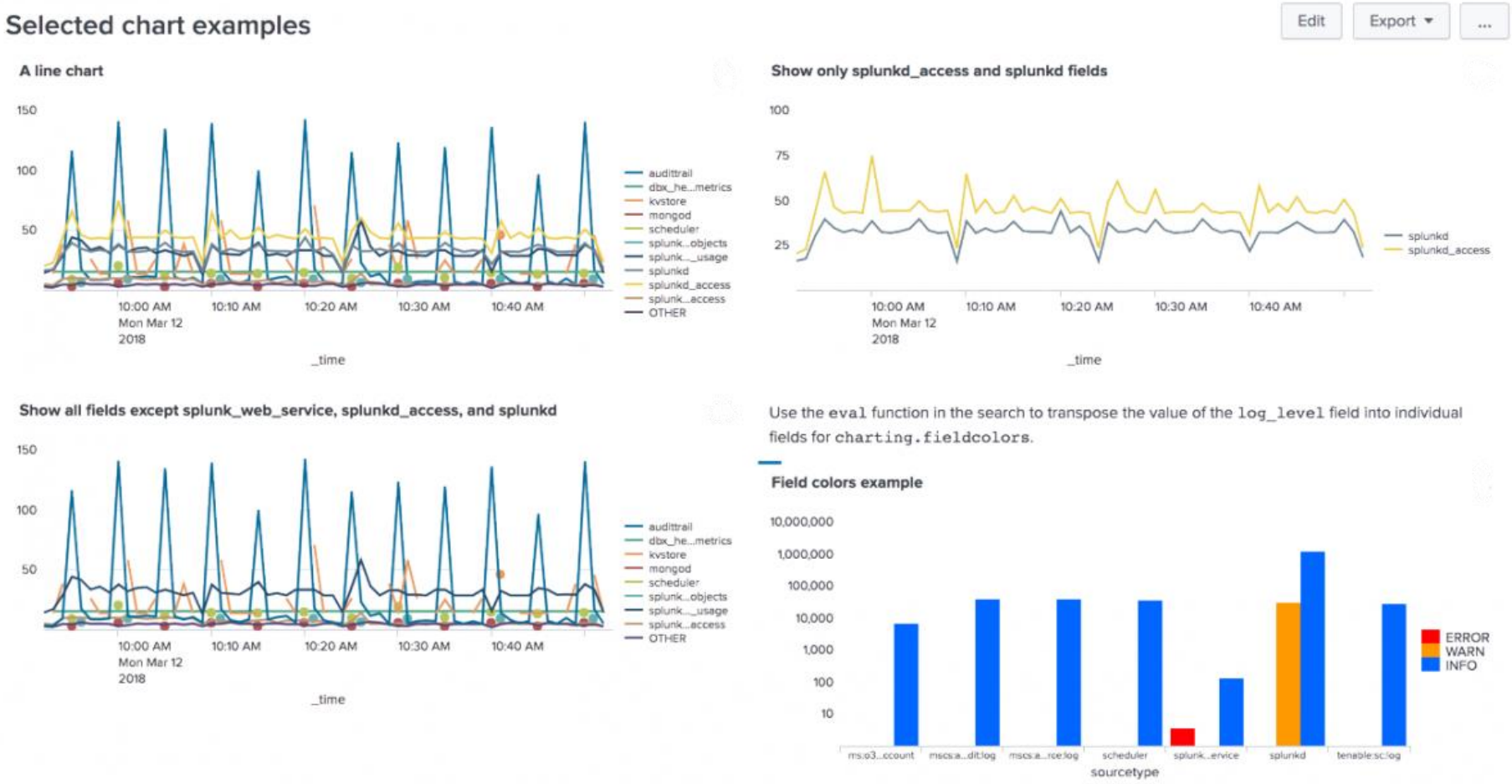
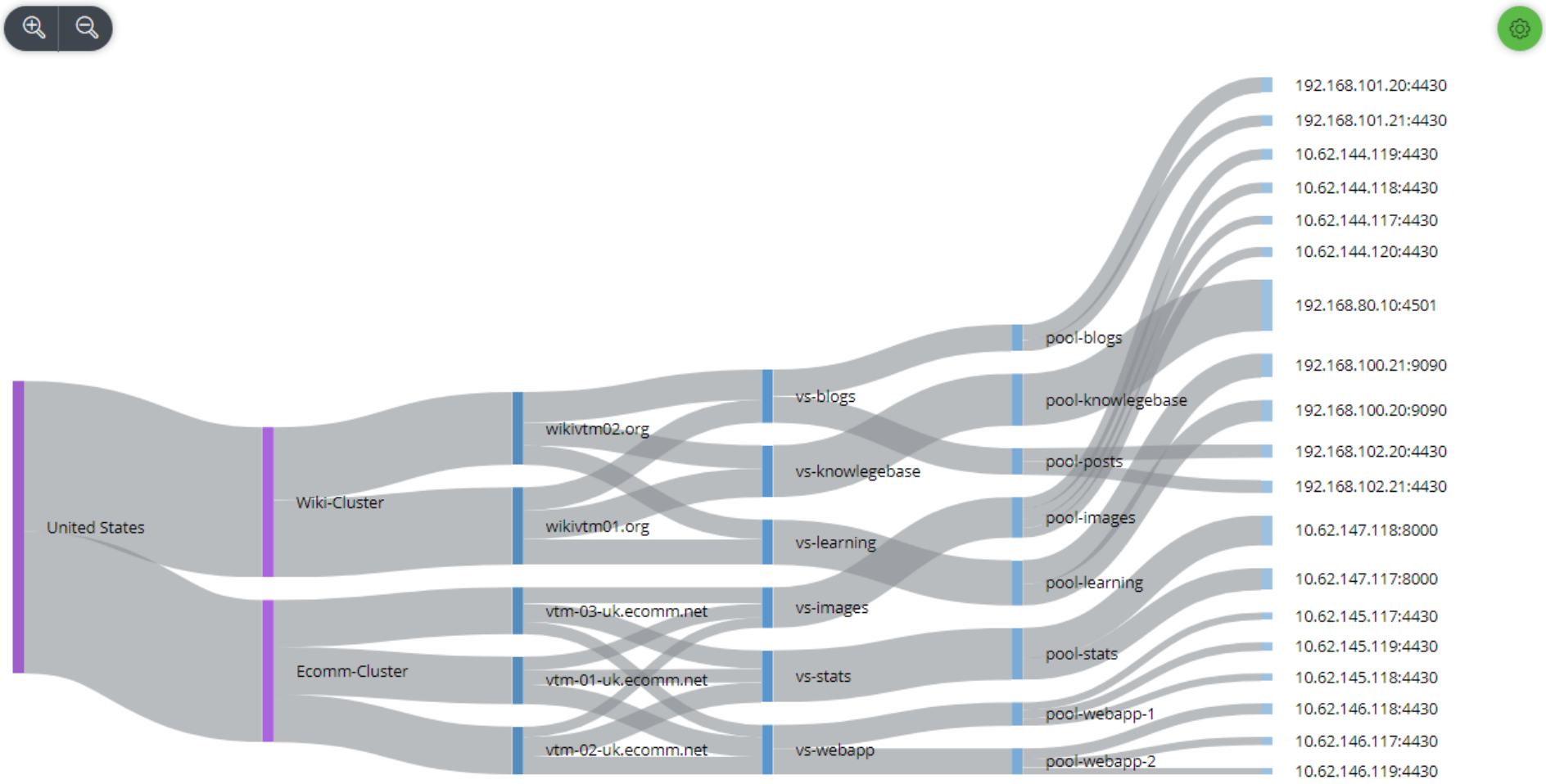



**Figure 1-4** Graphic display of log file entries


United States
Wiki-Cluster
Ecomm-Cluster
wikivtm02.org
wikivtm01.org
vtm-03-uk.ecomm.net
vtm-01-uk.ecomm.net
vtm-02-uk.ecomm.net
vs-blogs
vs-knowlegebase
vs-learning
vs-images
vs-stats
vs-webapp
pool-blogs
pool-knowlegebase
pool-posts
pool-images
pool-learning
pool-stats
pool-webapp-1
pool-webapp-2
192.168.101.20:4430
192.168.101.21:4430
10.62.144.119:4430
10.62.144.118:4430
10.62.144.117:4430
10.62.144.120:4430
192.168.80.10:4501
192.168.100.21:9090
192.168.100.20:9090
192.168.102.20:4430
192.168.102.21:4430
10.62.147.118:8000
10.62.147.117:8000
10.62.145.117:4430
10.62.145.119:4430
10.62.145.118:4430
10.62.146.118:4430
10.62.146.117:4430
10.62.146.119:4430

# Routing and Access Control Methods, Part 1

- Routers at the perimeter of a network are critical to the movement of all network traffic
  - Can be equipped with their own firewall software
- Attackers exploit open points of entry, such as
  - Vulnerable services – attackers might be able to exploit known vulnerabilities in an application
  - E-mail gateways – attackers might attach a virus to an e-mail message
  - Porous borders – an attacker might discover a port that a computer has left open that is not being used


© Cengage Learning 2014

# Routing and Access Control Methods, Part 2

- Three methods of access control
  - Mandatory Access Control (MAC) – all access capabilities are defined in advance
  - Discretionary Access Control (DAC) – allows users to share information with other users
    - Gives users more flexibility in accessing information
  - Role Based Access Control (RBAC) – establishes organizational roles to control access to information
    - Limits access by job function or job responsibility


© Cengage Learning 2014

# The Impact of Defense

- Cost of securing systems might seem high
- Cost of a security breach can be much higher
- Support from upper management
  - Key factor in securing systems
- Securing systems will require
  - Money
  - Time
  - Down time for the network
  - Support from upper management


© Cengage Learning 2014

# Summary, Part 1

- Network intruders are motivated by a variety of reasons
- Revenge by disgruntled, current, or former employees might be the primary motivation
- Some attackers break into accounts and networks for financial gain
- Some attackers may steal proprietary information for their own use or for resale to other parties
- E-mail is one of the most important services to secure


© Cengage Learning 2014

# Summary, Part 2

- Always-on connections present security risks that need to be addressed with firewall and VPN solutions
- Goals of network security
  - Confidentiality
  - Integrity
  - Availability
- An effective network security strategy involves many layers of defense working together to prevent threats
- Auditing helps identify possible attacks and prevent from other attacks


© Cengage Learning 2014

# Summary, Part 3

- Routers at the perimeter of a network are critical to the movement of all traffic
- Access control ensures that users can access resources they need but that unauthorized people cannot access network resources to exploit them
- Defense affects the entire organization
  - Always look for support from upper management


© Cengage Learning 2014